

NexusTech Solutions Security Policy Framework Practical Laboratory Report

GRC102 Week 2 Practical Laboratory

Submission detail	Entry
Student name	Adediran Eunice Adebukola
Registration number	C11-26-CGRCE-17 595
Course	GRC102 – Information Security Governance
Role in simulation	Information Security Manager, NexusTech Solutions
Submission date	18 September 2026
Evidence included	Bundles 1–5

This report contains a governance simulation prepared from the supplied NexusTech scenario. It does not contain live credentials, production evidence or confidential institutional information.

Executive overview

NexusTech has outgrown its five-year-old IT Rules document. The mixed content makes it difficult to know which statements are mandatory, who approves them and how staff should carry them out. This report establishes a clear document hierarchy, classifies the eight draft statements, provides an enforceable Acceptable Use Policy, and creates a repeatable access-request procedure. It also sets out how the new policy will be communicated and how it should be reviewed after the AWS migration and personal-cloud sharing incident.

Evidence bundle	Deliverable	Purpose
1	Policy hierarchy, classification and diagram	Separate governing rules from specifications, instructions and advice.
2	Acceptable Use Policy	Define permitted, limited and prohibited use of NexusTech resources.
3	User Access Request Procedure	Ensure every access grant is requested, approved, least-privileged and evidenced.
4	Communication and Training Plan	Turn approval into understood and measurable behaviour.
5	Policy Review Memo	Respond to material technology and incident-driven change.

Evidence Bundle 1 Security Policy Hierarchy

1.1 Documentation definitions

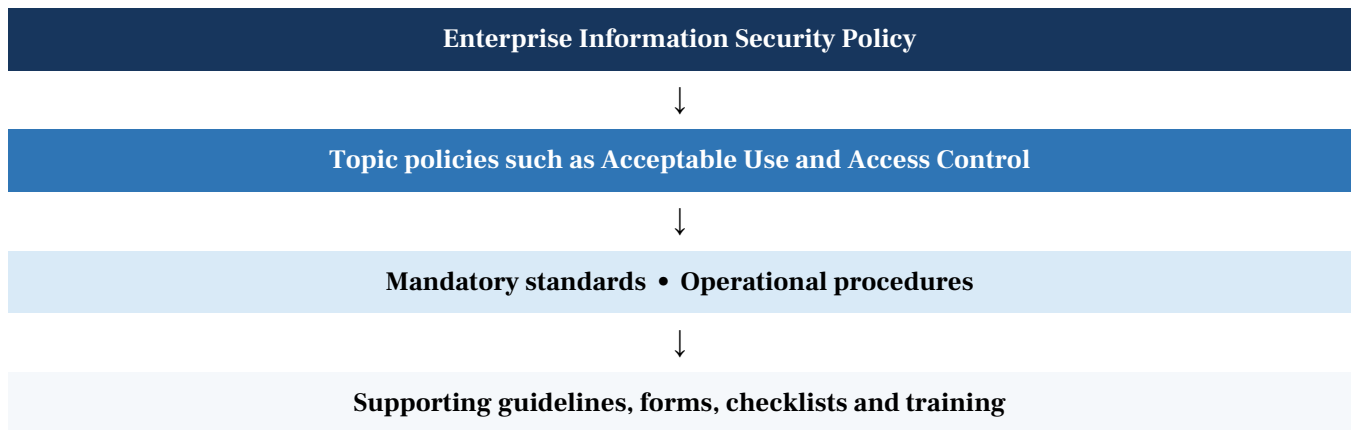
Document type	Purpose	Authority	Nature	Level of detail
Policy	States management intent, required outcomes, scope and accountability.	Approved by the CEO, Board or delegated executive authority.	Mandatory.	High level and stable; explains what and why.
Standard	Sets compulsory and measurable specifications that implement policy consistently.	Approved by the policy owner with the relevant technical or business authority.	Mandatory.	Specific thresholds, configurations or minimum requirements.
Procedure	Defines the ordered actions, approvals, records and escalation for completing a task.	Approved by the process owner under the governing policy and standard.	Mandatory when the process applies.	Detailed, sequential and action-oriented.
Guideline	Provides recommended practices and examples where judgement is appropriate.	Issued by a subject-matter owner.	Recommended unless adopted by a binding requirement.	Advisory detail, examples and options.

The hierarchy keeps policy durable while allowing technical details and working instructions to change at the correct level. A document called “Password Policy” should therefore state governing requirements or point to a password standard; Active Directory reset steps belong in a procedure.

1.2 Classification of NexusTech draft statements

No.	Condensed statement	Classification	Justification
1	All employees must use MFA for remote corporate-network access.	Policy	It states a mandatory organisation-wide access outcome without prescribing configuration steps.
2	Download the Authenticator app, scan the QR code and enter the six-digit code.	Procedure	It gives an ordered set of user actions for enrolling a device.
3	Developers are recommended to use parameterised queries.	Guideline	The wording recommends a secure development practice rather than establishing a mandatory control.
4	NexusTech is committed to confidentiality, integrity and availability of client data.	Policy	It expresses executive security direction and the organisation's intended protection outcome.
5	Corporate laptops must use BitLocker or FileVault full-disk encryption.	Standard	It sets a compulsory technical configuration and names acceptable technologies.
6	Employees should avoid unsecured public Wi-Fi while travelling.	Guideline	It advises safer behaviour but does not create an absolute rule or process.
7	For a suspected breach, contact the IT Helpdesk at extension 5555 immediately.	Procedure	It directs the user to take a specific incident-reporting action and channel.
8	Passwords must have at least 14 characters and specified character types.	Standard	It defines a measurable authentication threshold used to implement access policy.

1.3 Policy hierarchy diagram



Assurance sits across the hierarchy: approvals, version control, acknowledgements, access records, monitoring, audits, incidents and corrective actions show whether the documents are implemented and effective.

Evidence Bundle 2 Acceptable Use Policy

Document-control field	Approved entry
Policy title	NexusTech Solutions Acceptable Use Policy
Version	1.0
Policy owner	Information Security Manager
Approval authority	Marcus Vance, Chief Executive Officer
Effective date	18 September 2026
Review date	18 September 2027, or earlier if triggered
Classification	Internal

2.1 Purpose

This policy protects NexusTech information, clients, people and services by defining acceptable use of company accounts, devices, networks, software, communications and cloud services. It supports productive work while reducing malware, data leakage, legal and compliance risk.

2.2 Scope

This policy applies to employees, contractors, temporary staff, interns and other authorised users of NexusTech resources. It covers company-provided devices and accounts, corporate networks, approved cloud services, remote access, and personal devices authorised to access company information.

2.3 Definitions

Term	Meaning
NexusTech resource	Any company account, device, system, application, network, information or paid service.
Reasonable personal use	Limited use that is lawful, infrequent, does not interfere with work, create material cost or consume excessive capacity, and complies with this policy.
Sensitive information	Information requiring protection because of client, legal, contractual, commercial or security impact.
Approved service	A system or cloud service assessed and authorised through NexusTech's procurement, IT and security process.

2.4 Mandatory policy requirements

AUP 1 Authorised purpose. Users shall use NexusTech resources for legitimate business purposes and reasonable personal use only.

AUP 2 Credentials. Users shall use their own assigned accounts, protect passwords and authentication factors, and shall not share credentials or approve unexpected authentication requests.

AUP 3 Software. Users shall install or execute only software, browser extensions and scripts approved through the authorised IT process. Pirated or unlicensed software is prohibited.

AUP 4 Security controls. Users shall not disable, bypass, alter or attempt to evade endpoint protection, encryption, logging, filtering, access controls or other safeguards without written authorisation.

AUP 5 Information handling. Users shall access information only for authorised work and shall store, transfer and share it only through approved locations and communication channels.

AUP 6 Cloud and collaboration. Sensitive or client information shall not be uploaded to personal email, personal cloud storage, consumer file-sharing accounts or other unapproved services.

AUP 7 Prohibited conduct. NexusTech resources shall not be used for unlawful activity, harassment, fraud, unauthorised commercial activity, security probing without written approval, intellectual-property infringement, or creating and distributing malicious code.

AUP 8 Electronic communication. Users shall communicate professionally, verify unusual requests and treat unexpected links, attachments, payment instructions and credential prompts as suspicious.

AUP 9 Remote and travel use. Users shall use approved remote-access methods, prevent unauthorised viewing and avoid unsecured networks unless an approved secure connection is active.

AUP 10 Incident reporting. Loss, theft, misdirection, suspicious activity, malware, unexpected authentication prompts and suspected breaches shall be reported immediately to the IT Helpdesk at extension 5555 or through the approved service portal.

AUP 11 Monitoring. NexusTech may monitor and retain activity on company resources for security, service management, investigation and compliance where authorised and proportionate. Users should not expect personal privacy when using company-owned resources, subject to applicable law.

AUP 12 Return and deletion. On request, role change or separation, users shall return company assets, preserve official records and remove NexusTech information from personal locations under authorised direction.

2.5 Roles and responsibilities

Role	Responsibility
Users	Understand and follow the policy, protect resources, complete training and report concerns promptly.
IT and Security	Maintain approved services and controls, investigate events, advise users and retain appropriate evidence.
Managers	Set legitimate work expectations, approve access and exceptions within authority, and address local non-compliance.
Human Resources	Support onboarding, acknowledgement, fair disciplinary processes and separation activities.
Information Security Manager	Own the policy, maintain the exception register, monitor effectiveness and lead review.
CEO	Approve the policy and material revisions; provide visible sponsorship.

2.6 Compliance and enforcement

Compliance may be checked through endpoint, identity, network and cloud monitoring; service-desk and incident records; manager review; and internal audit. Suspected breaches will be assessed fairly. Depending on severity, intent

and recurrence, action may include advice, corrective training, removal of access, technical remediation, disciplinary action, contract remedies or referral to an appropriate authority. Good-faith reporting is protected from retaliation.

2.7 Exceptions

An exception must be approved before the non-compliant activity begins. The requester shall identify the exact requirement, business justification, scope, risk, compensating controls, owner and expiry date. The Information Security Manager assesses the request; the relevant business owner and policy owner approve or reject it. High residual risk requires CEO approval. All exceptions are recorded, reviewed and time-limited.

2.8 Approval and review

The CEO approves this policy. The Information Security Manager shall review it annually and after a material incident, legal or contractual change, major technology or cloud change, repeated exception, audit finding or significant change in NexusTech's risk profile. Revisions follow consultation, approval, publication and communication controls.

2.9 Related documents

- Enterprise Information Security Policy
- Access Control Policy and User Access Request Procedure
- Information Classification and Handling Standard
- Endpoint Security Standard
- Incident Response Procedure
- Policy Exception Request Form

Evidence Bundle 3 User Access Request Procedure

Document field	Entry
Procedure owner	IT Service Delivery Manager
Governing policy	Access Control Policy and Enterprise Information Security Policy
Version	1.0
Approved by	Information Security Manager and IT Director
Effective date	18 September 2026
Review date	18 September 2027

3.1 Purpose and scope

This procedure gives Helpdesk and identity administrators a consistent method for granting new or changed access. It applies to employee, contractor, service and third-party access to NexusTech systems, applications, cloud services, repositories and data. It does not replace the separate leaver or emergency incident-containment process.

3.2 Prerequisites and authorised roles

- An approved service-management ticket or identity workflow is required. Email or chat may provide supporting information but is not the system of record.
- The requester must identify the user, manager, employment or contract status, required system, business role, access level, start date and, for temporary access, end date.
- The line manager confirms business need. The system or data owner approves access to the resource. Human Resources or the authorised sponsor confirms the user's status.
- Only authorised identity administrators may create accounts or assign permissions. A person shall not request, approve and provision their own access.
- Approved role profiles and segregation-of-duties rules must be available. Where they are absent, the system owner must specify the least access needed.

3.3 Sequential procedure

Step	Action	Technician instruction
1	Receive and register the request	Confirm that it entered through the approved ticket or workflow. Record requester, user, system, role, requested access, start/end dates and business reason. Return incomplete requests without provisioning.
2	Verify identity and status	Match the user to the HR record or authorised sponsor information. Confirm the manager and employment/contract dates. Do not create access for an unverified identity.
3	Verify approvals	Check that the line manager approved the business need and that the system or data owner approved the resource and role. Confirm that approvals are attributable and current.
4	Check conflicts and prerequisites	Review segregation-of-duties conflicts, training, confidentiality agreement, licensing

Step	Action	Technician instruction
		and device requirements. Escalate conflicts to the system owner and Information Security Manager.
5	Determine least-privileged role	Select the approved role profile that meets the stated duties. Remove unnecessary permissions. Privileged, sensitive-data and production access require the additional approval specified by the access standard.
6	Create or modify the account	Use the authorised identity platform. Assign a unique identity, correct role and expiry date where applicable. Require MFA and approved authentication settings. Do not send a permanent password in the ticket.
7	Validate the result	Compare the granted permissions with the approved request. Where practicable, use a second-person check for privileged or high-risk access. Record the administrator and completion time.
8	Notify the user and manager	Send the approved access instructions, security responsibilities and support contact through an authorised channel. Ask the user or manager to confirm that access works and matches the request.
9	Capture evidence	Attach or link the approval record, role assigned, system confirmation, validation result, notification and any relevant exception. Do not place authentication secrets in the ticket.
10	Close the ticket	Close only after evidence is complete and the outcome is communicated. Record any rejected element and reason. Apply the retention category for access-control records.
11	Schedule review or expiry	Ensure temporary access expires automatically where possible. Add privileged or sensitive access to the relevant periodic access review.

3.4 Emergency and exceptional requests

Emergency access must be limited to a defined incident or urgent business need, use an attributable emergency account or time-limited role, and receive approval from the duty manager and system owner where available. If prior approval is impossible because delay would cause material harm, the technician shall record the reason and obtain retrospective approval by the next business day. Security shall monitor the activity, and the access must be removed immediately when the need ends. Any deviation from policy requires a recorded exception and compensating controls.

3.5 Records and audit trail

The service-management or identity system is the authoritative record. Tickets shall retain the request, identity/status verification, approvals, permission set, provisioning and validation evidence, notices, exceptions, dates and named actors. Records shall be protected from unauthorised alteration and retained under the corporate records schedule and applicable client or legal obligations.

Evidence Bundle 4 Communication and Training Plan

The objective is to make the AUP understandable before enforcement begins, teach role-specific duties, obtain attributable acknowledgement and identify areas that need clarification. The Information Security Manager owns the rollout; the CEO launches it visibly; Human Resources and IT provide completion and technical evidence.

Audience	Key message	Channel	Owner	Timing	Acknowledgement	Success measure
All employees and contractors	What acceptable, reasonable personal and prohibited use mean; credential, software, cloud-sharing and reporting duties.	CEO announcement, all-hands briefing, intranet summary and mandatory 25-minute learning module.	Information Security Manager and HR	Week 1 announcement; Weeks 2–3 training	Electronic attestation after knowledge check.	≥95% completion by end of Week 3; ≥80% first-attempt knowledge score; 100% within grace period.
Managers	Their approval, local enforcement, exception and escalation responsibilities.	Manager workshop, FAQ and manager checklist.	Security Manager and HR Business Partner	Week 1 before staff training	Attendance plus signed manager checklist.	100% managers briefed; all questions resolved or logged within five working days.
IT, Helpdesk and identity administrators	Approved software, monitoring boundaries, incident intake and the new access-request procedure.	Role-based workshop, procedure walk-through and sample-ticket exercise.	IT Service Delivery Manager	Week 1–2	Practical exercise sign-off.	≥90% exercise score; no access ticket closed without required approvals during the first-month sample.
Developers and cloud engineers	Approved tools, secure use of client data, privileged access and unapproved cloud-service risk.	Team session, secure-development channel posts and role-specific scenarios.	Engineering Director and Security	Week 2	Scenario completion recorded in LMS.	≥90% scenario score; decline in unapproved tools or public-sharing findings.
New starters	Core AUP duties before normal access is granted.	Onboarding module and policy acknowledgement.	HR and line manager	From effective date onward	HRIS/LMS attestation linked to onboarding.	100% completion within five business days of start.

4.1 Rollout timeline

Time	Activity	Output
Preparation week	Publish approved policy, configure LMS, prepare FAQ, brief managers and service desk.	Controlled policy copy, learning module, owner list and baseline measures.
Week 1	CEO announcement, all-hands briefing and manager/IT sessions.	Visible sponsorship and role-specific understanding.
Weeks 2–3	Mandatory training, knowledge checks, attestations and reminders.	Completion dashboard and question log.
Week 4	Grace-period follow-up and focused support for low-scoring groups.	Outstanding list, corrective learning and escalations.
Days 45–60	Sample monitoring, survey and management review.	Effectiveness report, lessons and improvement actions.
Quarterly	Short refreshers linked to incidents, seasonal risks and recurring misunderstandings.	Sustained awareness and trend data.

4.2 Escalation and effectiveness

Automatic reminders will be sent seven days and two days before the deadline. After the deadline, the learner and manager receive a notice. Continued non-completion moves to HR and the Information Security Manager; access may be restricted where acknowledgement is a condition of use. A failed knowledge check triggers a short refresher and retest. Repeated misunderstanding or non-compliance is addressed through coaching, control changes, formal corrective action or the disciplinary process, depending on risk and intent.

- Primary measures: training completion, policy acknowledgement and knowledge-check pass rate.
- Behaviour measures: rate of timely incident reports, unapproved software detections, personal-cloud sharing events, and access tickets with complete approvals.
- Quality measures: recurring questions, survey confidence, manager feedback and repeat incident causes.
- Management action: examine trends monthly for the first quarter, assign corrective owners and revise unclear material rather than relying only on completion percentages.

Evidence Bundle 5 Policy Review and Maintenance Memo

To	Information Security Steering Committee
From	Information Security Manager
Date	18 September 2026
Subject	Review of the Acceptable Use Policy following AWS migration and personal cloud sharing incident

Recommendation

I recommend an immediate out-of-cycle review of the Acceptable Use Policy. Moving the primary database to AWS changes where critical information is processed, the division of security responsibilities and the approved methods for administration, storage and sharing. The incident involving a sensitive document in personal cloud storage is direct evidence that the current wording or its implementation does not adequately prevent unapproved cloud use. Together, these are material technology and incident triggers; waiting for the annual review would leave an identified risk insufficiently addressed.

Review process and proposed changes

The review should be led by the Information Security Manager with the IT Director, AWS service owner, Legal or Privacy representative, Human Resources, Engineering, the affected business owner and Internal Audit or an independent reviewer. The team should examine the incident record, root cause, current AUP wording, AWS architecture and shared-responsibility record, cloud-service inventory, access and sharing logs, user feedback, training results, exceptions and relevant client obligations. A risk assessment should compare current controls with the target state, and proposed wording should be tested with representative users before approval.

I propose two minimum amendments. First, the AUP should state expressly that sensitive or client information may be stored or shared only through company-approved services, and that personal email, personal cloud storage and unauthorised file-sharing links are prohibited. Second, it should clarify that use of AWS administration, storage and data-export features requires approved accounts, MFA, least privilege, logging and authorised transfer methods. Supporting standards and training should identify the approved collaboration options, escalation route and examples of prohibited sharing. The Information Security Manager remains the policy owner; the Steering Committee reviews the revision, Legal and HR confirm relevant obligations and enforcement language, and Marcus Vance, CEO, approves version 1.1. The policy should remain on an annual cycle, with early review after a material incident, major cloud or system migration, significant legal or contractual change, repeated exception, audit finding or evidence that users consistently misunderstand a requirement.

References

- International Organization for Standardization. (2022). ISO/IEC 27 001:2022 Information security, cybersecurity and privacy protection Information security management systems Requirements.
<https://www.iso.org/standard/27001>
- National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework CSF 2.0.
<https://doi.org/10.6028/NIST.CSWP.29>
- International Cybersecurity and Digital Forensics Academy. (2026). GRC102 Week 2 Developing Security Policies and Procedures course material and practical laboratory brief.